学习任务单 S05:IAM 认证授权与多租户

学习领域 LF2 | 第 5 周 | 4 课时(180min)| 双元制六步法+费曼讲台

布鲁姆目标(本课你要达到)

- **[应]** 实现登录→取 token→携租户头调接口的完整脚本
- **[解]** 解释 JWT 三段结构与 claims(sub/roles/tenant_id)
- **[析]** 设计一条越权测试用例并解释预期

情境导入(资讯)

企业情境:法务要求'A 租户绝对不能看到 B 租户的数据'。今天你在真实 IAM 上验证多租户隔离,并写出能交给测试部的越权用例。

上节回顾

vendored 事故卡互评;工程师时间③(PF 规范)若本周排入。

计划与决策

1. 工单员领单,组内宣读目标与交付物;
2. 拆解实训步骤,分配操作员/检查员;
3. 向教师陈述 30 秒方案,重申安全红线(禁 L2/L3 越权操作)。

知识建构精讲要点(理论 35min,教师主持)

认证 vs 授权

- 认证=你是谁(iam 签发 JWT);授权=你能干什么(roles+网关校验)
- 角色链:SUPER_ADMIN/ADMIN/TENANT_ADMIN/STUDENT

JWT 结构实测

- 三段 header.payload.signature;payload=claims
- 本平台实测:sub=用户 UUID, roles=["ADMIN","SUPER_ADMIN"], tenant_id=UUID
- 注意:token 放 Authorization: Bearer;租户放 X-Tenant-Id 头

多租户隔离

- 数据隔离:租户字段过滤+行级隔离;接口隔离:@PreAuthorize 角色校验
- 越权用例模板:同租户低角色/跨租户同角色/无 token

实训实施(70min,双师巡回)

1. **1. 登录** — POST /api/v1/auth/login + X-Tenant-Id + {username:admin,password:Admin@12345}
2. **2. 解码** — base64 解 payload,抄下 sub/roles/tenant_id 三值
3. **3. 业务调用** — 携 token+租户头调 course 课程列表 → 200
4. **4. 越权实验** — 换租户头调数据 / 无 token / 低角色三分支,记录结果

检查清单(15min,检查员主持·互查组复核)

- □ [应] 登录脚本可重复执行(存 scripts/)
- □ [析] 越权三分支各有预期与实际对比
- □ [解] 能画出一次请求的身份传递链(JWT→网关→头→Filter)

费曼讲台(15min)

讲题:把 JWT 比作'景区手环':手环上写了什么?检票口认手环还是认脸?多租户=几个景区? 规程:白纸讲授 6min(不看笔记)→同伴追问 4min(卡壳即回炉)→类比压缩 3min。未过检查清单的小组不得上台。

课后作业

- 费曼卡#5:JWT 手环类比 200 字
- 提交可复用登录脚本+越权用例文件

评分点

脚本可复用性(40%)+越权分支完整性(40%)+身份链讲解(20%)

证据纪律:所有'完成'必须附命令输出/截图;如实记录失败与返工(诚实=加分)。